COLORADO
Information Security
Governor's Office of Information Technology

# CISP-003: Information Technology Security Risk Management Policy

| | |
|---|---|
| **Document ID** | CISP-003 |
| **Title** | Information Technology Security Risk Management Policy |
| **Executive Sponsor** | Jill Fraser, Chief Information Security Officer |
| **Issuing Authority** | Governor's Office of Information Technology (OIT) |
| **Applies to** | All public agencies as defined by C.R.S. 24-37.5-102(26). Not intended to govern state IT resources made available for public use (e.g., public Wi-Fi in state facilities). All contracted parties must comply with these requirements. |
| **Instrument Type** | Policy |
| **Version** | 4.0 |
| **Effective Date** | 07/01/2026 |
| **Last Updated** | 03/09/2026 |

## 1. Purpose

This policy supports the State of Colorado Chief Information Security Officer (CISO) in achieving the requirements of the Colorado Information Security Act (C.R.S. 24-37.5-401, et seq.). It governs information technology security risk management for State of Colorado IT resources by public agencies and users.

## 2. Applicability

This policy applies to all public agencies as defined by C.R.S. 24-37.5-102(26). It is not intended to govern the use of state IT resources made available for public use (e.g., public Wi-Fi in state facilities). All contracted parties must comply with these requirements.

## 3. Defined Terms

All CISP-specific terms are defined in the CISP Glossary unless otherwise defined in this policy.

## 4. Policy

All state IT resources, information and data are the sole property of the State of Colorado, and applicable statutes, policies, and technical standards govern their use. Public agencies must manage and mitigate IT security risk in accordance with this policy.

# 5. IT Security Planning

## Agency Cyber Security Plan (Non-consolidated)

Non-consolidated agencies must work with their information security officer to develop an annual cyber security plan for their agency, in accordance with Rule 8 CCR 1501-5 and this policy.

## Enterprise Cyber Security Plan (Consolidated)

The Office of Information Technology (OIT) must create a consolidated, integrated enterprise cyber security plan for all consolidated agencies in compliance with Rule 8 CCR 1501-5 and this policy.

# 6. Securing IT Assets and Software

- Secure Configuration of IT Assets and Software: OIT must identify minimum configuration standards for IT assets and software solutions.
- Configuration Change Control: OIT and the agency must have a documented procedure for system configuration control.
- Access Restrictions for Change: OIT must have a standard to support personnel access control to IT systems.
- Configuration Settings: The technology provider must comply with technical standards.
- Software Installation: OIT must establish written procedures for software installation.
- Lifecycle Management: The technology provider must have a lifecycle plan ensuring the solution is maintained according to standards throughout its lifetime.
- Maintenance: The technology provider, with the agency, must define monthly maintenance windows and allowable downtime, and schedule, perform, document, and review maintenance and repairs.
- Maintenance Tools: The technology provider must implement, control, monitor, and maintain maintenance tools; prevent removal of equipment containing agency data; and restrict tool use to authorized personnel.
- Maintenance Personnel: OIT must establish, and providers must follow, a process for authorizing in-person maintenance personnel, including supervision of unescorted personnel without required access authorizations.

# 7. Managing and Mitigating IT Risk

- IT Risk Management: OIT must establish, maintain, and document an IT risk management program.
- Data Categorization: OIT must work with the agency to categorize data and maintain documentation of the categories; system criticality classification must be performed.
- Vulnerability Scanning: OIT must establish and maintain processes for regularly scanning for vulnerabilities, analyzing and remediating, and sharing results with the agency and stakeholders.

# 8. IT Supply Chain Management

OIT must establish, maintain, and document an IT supply chain management process.

- Software Supply Chain: The technology provider must maintain an updated inventory of supply chain software and provide it upon request to the information security office.
- IT Acquisition Process (Procurement): OIT, with the agency and procurement team, must include state requirements in agreements and ensure the supply chain meets the Colorado Information Security Policies, technical standards, and agency-specific requirements, including review and monitoring.

# 9. Protecting IT Systems and Communications

OIT must establish, maintain, and document a system and communications protection plan and process addressing:

## Secure Configuration and Infrastructure

- Ensure only supported browsers and email clients are used, and maintain email server protections.
- Maintain a secure network infrastructure.
- Ensure the information system defaults to a safe and predictable state in the event of failure.

## Data Protection

- Protect the confidentiality, integrity, and availability of data in transit, in use, and at rest.
- Prevent unauthorized and unintended information transfer via shared resources.

## Network Security

- Monitor and protect boundary communications, segment internal and external networks, and connect to external systems only through managed interfaces.
- Ensure the information system terminates network connections after a session ends or after a set period of inactivity.
- Establish usage restrictions and guidance for VoIP technologies, and monitor, control, segment, authorize, or deny access based on risk.

## Email Verification

- Establish a comprehensive email authentication standard across all domains to verify sender identity, ensure message integrity, and defend against spoofing.

## Authentication and Encryption

- Establish and manage cryptographic keys according to laws and regulations.
- Issue public key certificates under a defined policy or obtain them from a trusted certificate authority.
- Protect the authenticity of communications sessions.
- Define secure mobile code technologies, establish usage restrictions and implementation guidance, and manage and monitor their use.

# 10. Asset Management

OIT and the technology provider must establish, maintain, and document an IT asset management plan and process that:

- Maintains a current IT asset inventory to record all IT hardware.
- Maintains a current record of licensed and authorized software.
- Ensures only approved software is used on IT assets.

# 11. Access Control Management and User Security

## Account Management

OIT, the technology provider, and the agency must manage credentials for all user accounts (including privileged and service accounts, IT assets, and software). The technology provider and agency must:

- Maintain an inventory of all active accounts.
- Authorize user accounts.
- Ensure each account type uses unique credentials.
- Enforce strong password policies.
- Continuously identify, monitor, and manage inactive accounts.
- Manage, verify, revoke, and regularly audit digital identities and credentials.
- Require strict least privilege.
- Prevent account or identifier reuse.

## Access Control Management

- Manage IT asset access.
- Require multifactor authentication (MFA) on all privileged accounts and for all remote access.
- Ensure data is transmitted securely only to authorized recipients.
- Enforce separation of duties.

## Information Sharing

Where required, the technology provider must enable secure data sharing and, with partner technology providers, ensure they have similar or stronger data protection controls as those required by the agency and applicable laws and regulations.

# 12. Security Awareness Training and Education

Every user must receive and complete assigned security awareness training. Records of compliance and non-compliance must be maintained for each user. Training must be completed at least annually, and public agencies may need to supplement OIT-created training based on agency-specific needs.

# 13. Compliance

Failure of users to comply with this policy may result in, as applicable:

- Loss of federal grant funding, fines and penalties.

- Agency-level sanctions regarding state IT resources: restriction, deactivation, or suspension of the user's account, project, or system, or termination of employment.
- Termination of contract or assignment for temporary workers, interns, volunteers, contractors, or vendors who violate this policy.

Non-consolidated agencies must have appropriate policies and procedures to ensure compliance with this policy and all other Colorado Information Security Policies.

## 14. Exceptions

Any exceptions to this policy must be documented, justified, and approved in advance of implementation. Requestors must submit a Secure Configuration Exception Request.

## 15. References

- Colorado Information Security Act (C.R.S. 24-37.5-401, et seq.)
- Colorado Open Records Act (C.R.S. § 24-72-200.1, et seq.)
- Colorado Information Security Act - Rules (8 CCR 1501-5)
- State of Colorado Universal Policies
- Secure Configuration Exception Request in ServiceHub
- US Government ITAR country list
- Password & Account Management Requirements Chart
- Colorado Information Security Policy - CISP Information Security Glossary